

UNIDADE CURRICULAR: GOVERNANÇA DE TI

Governança Corporativa & SOX

Princípios IBGC, Controles Internos (ITGC), Compliance e Ética na TI

Prof. André Souza

SENAI — Serviço Nacional de Aprendizagem Industrial

Estrutura da Aula

1. Governança Corporativa

- ▶ Teoria da Agência e conflito de interesses.
- ▶ Os 4 Princípios Universais do IBGC.

2. Lei Sarbanes-Oxley (SOX)

- ▶ Seções 302 e 404 da lei.
- ▶ Os 4 domínios do ITGC (Controles de TI).

3. Compliance & Integridade

- ▶ Conformidade legal e dilemas éticos.
- ▶ Casos reais: Enron e Volkswagen.

4. Capítulo 1 do PDGTI

- ▶ Caracterização da Organização-Alvo.
- ▶ Mapeamento da estrutura de TI e negócio.

O que é Governança Corporativa?

Definição e Âmbito

- ▶ Sistema pelo qual as empresas são dirigidas e monitoradas.
- ▶ Envolve sócios, conselho, diretoria e órgãos de fiscalização.
- ▶ Foco na perenidade e sustentabilidade do negócio.

Conexão com a TI

- ▶ A TI é o meio por onde 100% dos dados corporativos trafegam.
- ▶ Sem governança na TI, a governança corporativa é vulnerável.

A Teoria da Agência (Conflito de Agência)

O Principal (Acionista)

- ▶ Busca o crescimento sustentável de longo prazo.
- ▶ Necessita de garantias e auditoria sobre a operação.

O Agente (Executivo contratado)

- ▶ Gerencia o negócio no dia a dia.
- ▶ Pode focar em metas de curto prazo para obter bônus.
- ▶ Exige controles rígidos de governança para alinhamento.

Princípio 1: Transparência (Transparency)

Conceito do IBGC

- ▶ Disponibilização espontânea de informações relevantes.
- ▶ Clareza sobre o verdadeiro estado da organização.

Aplicação Prática na TI

- ▶ Dashboards executivos de SLAs e indisponibilidades.
- ▶ Transparência de custos de infraestrutura e nuvem (FinOps).
- ▶ Comunicação clara de falhas e incidentes de segurança.

Princípio 2: Equidade (Fairness)

Conceito do IBGC

- ▶ Tratamento justo e isonômico a todas as partes.
- ▶ Eliminação de privilégios ou favorecimentos.

Aplicação Prática na TI

- ▶ Priorização de projetos baseada em critérios objetivos de ROI.
- ▶ Atendimento de suporte baseado em criticidade, não em cargos.

Princípio 3: Prestação de Contas (Accountability)

Conceito do IBGC

- ▶ Responsabilização integral pelos atos e omissões.
- ▶ Clareza sobre papéis e deveres dos gestores.

Aplicação Prática na TI

- ▶ Donos de Dados e Sistemas (Data Owners) definidos.
- ▶ Matriz RACI explícita para todos os processos de TI.
- ▶ Registros de auditoria (audit trail) imutáveis.

Princípio 4: Responsabilidade Corporativa

Conceito do IBGC

- ▶ Zelo pela sustentabilidade financeira, social e ambiental.
- ▶ Impacto a longo prazo na sociedade.

Aplicação Prática na TI

- ▶ TI Verde (Green IT): eficiência energética em servidores.
- ▶ Descarte ecológico e certificado de e-waste.
- ▶ Proteção rigorosa de dados pessoais e privacidade.

Origem da Lei Sarbanes-Oxley (SOX)

O Contexto Histórico (2002)

- ▶ Grandes escândalos financeiros (Enron, WorldCom).
- ▶ Manipulação de balanços e destruição de provas contábeis.
- ▶ Quebra da confiança dos investidores mundiais.

Objetivo da Lei

- ▶ Exigir demonstrações financeiras rigorosamente auditáveis.
- ▶ Responsabilizar criminalmente executivos por fraudes.

Seções 302 & 404 da Lei SOX

Seção 302 (Assinatura Executiva)

- ▶ Exige que o CEO e o CFO atestem pessoalmente os relatórios.
- ▶ Responsabilidade pessoal direta por omissões ou erros.

Seção 404 (Controles Internos)

- ▶ Avaliação anual da eficácia dos controles internos (ICFR).
- ▶ Auditoria externa independente obrigatoriamente acoplada.

Controles Gerais de TI (ITGC)

Acessos & Mudanças

- ▶ **Acessos Lógicos:** Autenticação, MFA e menor privilégio.
- ▶ **Mudanças (Change Management):** Segregação Dev/Prod.

Operações & Desenvolvimento

- ▶ **Operações:** Backups imutáveis e plano de Disaster Recovery.
- ▶ **Desenvolvimento:** Versionamento seguro e homologação.

Compliance Regulatório vs. Cultura Ética

Compliance Regulatório

- ▶ Cumprir leis, normas e regulamentos (obrigação formal).
- ▶ Foco em evitar multas, sanções e processos.

Cultura Ética & Integridade

- ▶ Fazer o correto mesmo quando ninguém está olhando.
- ▶ Responsabilidade profissional sobre o código e algoritmos.

Enron & Volkswagen Dieselgate

Caso Enron (Falha de Controle)

- ▶ Fraude contábil velada por empresas de fachada.
- ▶ Destruição de relatórios - ¿ Surgimento da SOX e ITGC.

Caso Dieselgate (Dilema Ético)

- ▶ Software programado para fraudar testes de emissão de poluentes.
- ▶ Responsabilidade criminal sobre os engenheiros de software.

Fontes & Leitura Recomendada

Obras de Referência

- ▶ **BITTENCOURT, Carlos Magno Andriolli.** *Governança corporativa e compliance: planejamento e gestão estratégica.* Curitiba: Contentus, 2020.
- ▶ **MARTINS, Camila Saldanha.** *Governança e compliance.* Curitiba: Contentus, 2020.
- ▶ **IBGC.** *Código das Melhores Práticas de Governança Corporativa.* 6. ed. São Paulo: IBGC, 2023.

Desenvolvimento do Capítulo 1

Capítulo 1 – Caracterização da Organização

- ▶ **1.1 Visão Geral do Negócio:** Setor, porte, missão, visão e valores.
- ▶ **1.2 Estrutura Organizacional:** Organograma corporativo e diretoria.
- ▶ **1.3 Estrutura de TI:** Organograma atual da TI e equipe.
- ▶ **1.4 Inventário Simplificado:** Sistemas principais (ERP/CRM), infraestrutura e orçamento.